Case 03 · מודל איום: שני השורדים

מודל איום משותף ל-*Roll Transparency Log* ול-*Removal Sample Audit*, בשיטת *STRIDE* מותאמת: מי התוקף, מה הוא רוצה, איך הוא מנסה, ומה כל מערכת עושה מולו. הדמויות והתרחישים בדויים; המספרים מה-*POC* של התיק.

מה מגינים עליו

- השלמות של העבר: שאף שינוי ברשימה לא יעלם או ישתנה אחרי שנרשם.
- הזמן של הבוחר: שאדם שנמחק ידע מספיק מוקדם כדי לערער.
- הפרטיות של השכנים: שהשקיפות לא תהפוך למפה של מי עבר ומי נפטר.
- האמת של המספר: שאומדן מחוזי לא יהיה מוטה בשקט.

מי התוקפים

תוקף	מה הוא רוצה	מה יש לו
מפעיל פנימי בוועדה	למחוק או לשנות בלי שיראו	גישה לשרתים, לקוד ולמסד
קצין רישום לחוץ	לעמוד ביעד המחיקות	מסוף, הרשאה לבחור קוד
גורם פוליטי מקומי	ללמוד מי עבר, ומאיזו קהילה	גישה לכל מה שציבורי
מתחזה	לבדוק בוחר אחר, או לשלוח SMS מזויף	מספר תעודה של מישהו אחר
בודק שטח מהמנגנון	לאשר מחיקות בלי לבקר	אפליקציית השטח

איומים על Roll Transparency Log

#	איום (STRIDE)	תרחיש	ההגנה	מצב
T1	Tampering	המפעיל משנה שורה ישנה ובונה את העץ מחדש	הוכחות עקביות; עדים שומרים ראשים ישנים. ב-POC: נתפס	נסגר
T2	Spoofing של היומן	תצוגה מפוצלת: עץ אחד לפריה, אחר לעיתונאי	ראש תקף רק עם 3 מתוך 5 עדים, והעדים משווים ביניהם	נסגר
T3	Repudiation	שינוי בפנקס שעוקף את היומן	אין "נשמר" בלי קבלה; מתאם לילי בונה את הפנקס מהיומן ומשווה	נסגר
T4	Information disclosure	שכן קורא ביומן מי עזב את הכפר	ציבורי רק מחוז ושבוע. ב-POC: כמעט כל קלפי מתחת ל-5 שינויים	נסגר, עם DPIA
T5	Information disclosure	מילון של מספרי תעודה מול כינויים	HMAC עם מפתח בתוך HSM; בלי המפתח אין מילון	נסגר
T6	Spoofing של בוחר	מישהו בודק בוחר אחר עם המספר שלו	נדרש גם תאריך לידה; הגבלת קצב; אין חשיפה מעבר לשורה	חלקי
T7	Denial of service	בוקר הטיוטה: מיליונים בודקים יחד	אריחים סטטיים ב-CDN; השרת מחשב רק כינוי	נסגר
T8	Tampering של	קצין כותב R-DEAD	שדה ראיה חובה	פתוח בחלקו: היומן

	התוכן	על אדם חי	לכל קוד; האדם מקבל SMS ויכול לערער	לא יודע מה נכון
T9	Phishing	SMS מזויף "נמחקת, לחץ כאן"	שולח מזוהה; ההודעה לא מבקשת פרטים; האימות בטלפון מול ראש חתום	חלקי

איומים על Removal Sample Audit

#	איום	תרחיש	ההגנה	מצב
A1	Tampering של המדגם	מישהו בוחר מדגם נוח	seed ציבורי שהוכרז מראש; הגרלה ניתנת לשחזור	נסגר
A2	Tampering של הרשימה	מוסיפים מחיקות "נכונות" אחרי ההגרלה	הקפאה וחתימה של הרשימה לפני ההגרלה	נסגר
A3	Tampering של האמת	בודק מהמנגנון מאשר בלי לבקר. ב-POC: רבע אישורים מוריד את האומדן ל-11% וכיסוי ל-1.8%	ביקור חוזר, צילום דלת ומיקום; אבל אין מי שיקים מאגר בודקים עצמאי, ומי שזמין שייך למנגנון	פתוח: הסיבה שנפל
A4	Information disclosure	רשימת 1,500 כתובות שנבדקו דולפת	רשימה מוצפנת לבודקים בלבד; תוצאות מצרפיות	נסגר
A5	מניפולציה של המסר	"11% שגויות" הופך לסיסמה	המספר תמיד עם טווח, שיטה ו-seed	חלקי

מה מודל האיום שינה בתכנון

- ביומן: פרסום מצרפי במקום שורה מלאה (T4); חתימת עדים כתנאי לתוקף (T2); שדה ראיה חובה (T8).
- בביקורת: הקפאת הרשימה (A2). ו-A3 נשאר פתוח, וזה מה שהפיל אותה בארכיטקטורה.

מה נשאר פתוח

- **T8**: היומן מוכיח מה נרשם, לא שמה שנרשם נכון. ההגנה היחידה היא שהאדם יודע בזמן ויכול לערער.
- **T6/T9**: בלי זהות דיגיטלית חזקה לכל בוחר, בדיקה עצמית ו-SMS תמיד יהיו פתוחים לחלק מההתחזויות.